

Cybersecurity: Advanced cryptography

The **authentication** and **distribution** of public keys through digital certificates is an essential Cryptography application in enterprises.

Please provide a **short and concise** definition/explanation for each of the cybersecurity terminologies. Each definition/explanation entry is worth **5** points.

Direction & Submission: use the downloaded document, provide the definition/explanation for each indicated row below. At the completion, submit the completed document through Canvas. You have up to **two weeks** to submit the assignment after the due date. Please note that there is a daily 3% deduction if submitted after the due date.

	Terms	Definition/explanation
1	A digital certificate	is an electronic document issued by a trusted Certificate Authority (CA) that verifies the identity of an entity and contains a public key, enabling secure communication and authentication in cryptographic systems.
2	A trusted third party	is an entity that facilitates secure communications and transactions between parties by verifying identities, issuing digital certificates, and ensuring data integrity and confidentiality.
	Managing Digital Certificates	
3	Certificate Repository (CR)	is a centralized storage system that securely maintains and distributes digital certificates and their status, allowing users and systems to verify the authenticity of certificates issued by a Certificate Authority (CA).
4	Certificate Revocation	the process of invalidating a digital certificate before its expiration date, typically due to compromise, misuse, or changes in the entity's status, ensuring it is no longer trusted for authentication or encryption.
5	Status certificate check	is the process of verifying the current validity of a digital certificate by checking its status against a Certificate Revocation List
6	• Certification revocation list (CRL)	is a list published by a Certificate Authority (CA) that contains the serial numbers of digital certificates that have been revoked before their expiration date, along with the reasons for revocation.
7	• Online certificate status protocol (OCSP)	is a protocol used to check the revocation status of a digital certificate in real-time, allowing clients to verify whether a certificate is valid, revoked, or unknown without needing to download a full Certification Revocation List (CRL).
8	Stapling	refers to a technique in which a server includes a time-stamped OCSP (Online Certificate Status Protocol) response with its SSL/TLS handshake, effectively "stapling" the revocation status of its certificate to the connectio
	Types of digital Certificates	

9	Root digital certificates	are the highest-level certificates in a public key infrastructure (PKI) hierarchy, issued by a trusted Certificate Authority (CA). They are used to validate the authenticity of intermediate certificates and, ultimately, digital certificates for websites or services.
10	Certificate chaining	is the process of linking a digital certificate to a trusted root certificate by using intermediate certificates.
11	Root of trust	refers to a trusted entity, typically a root certificate or hardware module, that is the foundation for establishing the authenticity and security of a system or network
12	Root digital certificate (self-signed)	is a certificate that is signed by its own private key, rather than by a trusted Certificate Authority (CA). It serves as the anchor of trust in a public key infrastructure (PKI) and is typically used for internal systems or self-managed infrastructures
13	Intermediate certificates	certificates that act as a bridge between a root certificate and an end-entity (or leaf) certificate in a certificate chain
14	User digital certificate	is an electronic document that verifies the identity of a user, typically in an online environment, and contains the user's public key.
	Domain Digital Certificates	
15	Domain validation digital certificate	is a type of SSL/TLS certificate that verifies the ownership of a domain name but does not require extensive identity validation of the organization behind the domain.
16	Extended validation (EV)	is a type of SSL/TLS certificate that provides the highest level of validation for a website's identity. It involves a thorough vetting process by the Certificate Authority (CA), including verifying the legal, physical, and operational existence of the organization.
17	Wildcard digital certificate	is an SSL/TLS certificate that allows a single certificate to secure multiple subdomains of a domain. It is issued for a primary domain (e.g., .example.com) and can be used to secure any subdomain, such as www.example.com , mail.example.com, or shop.example.com
18	Subject Alternative Name (SAN)	is an extension to an SSL/TLS certificate that allows multiple domain names or IP addresses to be secured within a single certificate.
19	Hardware and Software Digital Certificates	are certificates stored on physical devices, such as smart cards, USB tokens, or Hardware Security Modules (HSMs). These devices provide a higher level of security by ensuring that private keys are not exposed to the computer or network. Software Digital Certificates are stored on a computer's storage or server, usually in the form of a file. While more convenient, they may offer less security than

		hardware-based certificates since they are vulnerable to being compromised if the device is compromised.
20	Machine/computer digital certificate	is an SSL/TLS certificate issued to a specific machine or computer, used for authenticating the device in network communications.
21	Code signing digital certificate (code signing)	is used by software developers to digitally sign their software, ensuring its authenticity and integrity. It verifies that the code has not been tampered with since it was signed and identifies the publisher
22	Email digital certificate	is a type of digital certificate used to secure email communications by enabling encryption and digital signatures
23	Digital certificate attributes and formats	are the components that define and describe the information contained within a digital certificate.
	Public Key Infrastructure (PKI)	
24	PKI	is a framework of policies, technologies, and procedures used to manage digital keys and certificates. It enables secure communication, authentication, and encryption over networks by using a combination of public and private key cryptography.
25	Trust Models	describe how trust is established and maintained between users, organizations, and certificate authorities (CAs)
26	Direct trust	is a trust model where two parties establish trust with each other without the involvement of a third-party authority, such as a Certificate Authority (CA).
27	Third-party trust	is a trust model where two parties rely on a trusted third-party entity, such as a Certificate Authority (CA), to validate and verify each other's identity.
28	Web of trust	is a decentralized trust model used primarily in systems like PGP (Pretty Good Privacy), where users validate and sign each other's digital certificates.
	Hierarchical Trust	
29	Certificate Authority (CA)	is a trusted organization or entity responsible for issuing, managing, and validating digital certificates within a public key infrastructure (PKI).
30	Distributed Trust Model	is a decentralized trust system where trust is spread across multiple entities or participants rather than relying on a single central authority, such as a Certificate Authority (CA).
31	Bridge Trust Model	is a trust framework that connects multiple Public Key Infrastructures (PKIs) to enable cross-organization or cross-domain trust.

	Managing PKI	
34	Certificate policy (CP)	is a set of rules and guidelines that defines the practices, requirements, and procedures followed by a Certificate Authority (CA) when issuing, managing, and revoking digital certificates.
35	Certificate practice statement (CPS)	a detailed document that outlines the specific practices, procedures, and obligations a Certificate Authority (CA) follows to implement the policies defined in a Certificate Policy (CP).
36	Certificate life cycle	refers to the series of stages a digital certificate goes through from issuance to expiration or revocation
37	creation	in the context of a digital certificate life cycle refers to the initial phase where a Certificate Authority (CA) generates a certificate after receiving a valid request.
38	suspension	in the context of a digital certificate life cycle refers to the temporary invalidation of a certificate by the Certificate Authority (CA). During suspension, the certificate remains technically valid but is not trusted for authentication or encryption purposes.
39	revocation	refers to the process of invalidating a certificate before its expiration date. This typically occurs when the certificate's private key is compromised, the certificate is no longer needed, or the identity of the certificate holder is no longer valid.
40	expiration	refers to the automatic invalidation of a certificate once it reaches its predefined validity period. After expiration, the certificate is no longer considered valid for authentication or encryption purposes.
	Key Management	
41	Key storage	refers to the secure storage of cryptographic keys, including private and public keys, used in encryption, digital signatures, and authentication processes. Secure key storage ensures that keys are protected from unauthorized access, theft, or compromise.
42	Key usage	refers to the specific purposes for which a cryptographic key is allowed to be used, as defined in the certificate or key management system.
43	Key handling procedures	are the established practices and protocols for managing cryptographic keys throughout their life cycle. These procedures cover the creation, storage, distribution, usage, revocation, and destruction of keys to ensure their confidentiality, integrity, and availability.
44	escrow	the practice of storing a copy of a cryptographic key in a secure, third-party repository for future use, typically in case the key owner is unavailable or the key is needed for legal or operational purposes.

45	• expiration	refers to the predefined end date or time after which a cryptographic key, certificate, or token is no longer valid.
46	• renewal	Regularly updating or replacing keys to minimize the risk of compromise.
47	• revocation	Invalidating keys if they are no longer secure or needed.
48	• recovery	the process of restoring access to encrypted data or cryptographic keys when they are lost, compromised, or inaccessible.
49	• suspension	temporarily invalidating a certificate or key without permanently revoking it. During suspension, the certificate or key cannot be used for authentication or encryption, but it may be reinstated if the issue causing the suspension is resolved.
50	• destruction	safely erasing keys when they are no longer required or have expired.
Secure communication and transport protocols (data in transit)		
51	tunneling	refers to the practice of encapsulating one type of network traffic within another to securely transmit data across an insecure or untrusted network.
52	Secure Sockets Layer (SSL)	is a cryptographic protocol designed to provide secure communication over a computer network, primarily the internet. It uses encryption to protect the data transmitted between a client (such as a web browser) and a server, ensuring confidentiality, integrity, and authentication
53	Transport Layer Security (TLS)	designed to provide secure communication over a computer network, replacing the older SSL protocol. TLS encrypts the data exchanged between a client (such as a web browser) and a server, ensuring privacy, integrity, and authentication of the transmitted information.
54	Internet Protocol Security (IPSec)	is a suite of protocols designed to secure internet protocol (IP) communications by encrypting and authenticating data at the IP layer. It provides a secure way to transmit data over IP networks by ensuring confidentiality, integrity, and authentication.
55	• Applications	Virtual Private Networks (VPNs) Site-to-Site Communications End-to-End Encryption Securing VoIP and Multimedia Traffic Protecting Wireless Networks Secure Online Transactions

56	• users	Organizations and Enterprises Remote Workers Cloud Service Providers Government Agencies Internet Service Providers (ISPs) End Users
57	• software	VPN Software Firewall Software Network Security Appliances Antivirus and Endpoint Protection Software Router Firmware Cloud Security Solutions
58	Area of protection by IPSec	Data Confidentiality Data Integrity Authentication Access Control Traffic Flow Confidentiality
59	• authentication	in IPSec refers to the process of verifying the identity of the parties involved in a communication, ensuring that the sender and receiver are legitimate and trusted.
60	• Confidentiality	in IPSec ensures that data transmitted over a network is encrypted, preventing unauthorized access and ensuring that sensitive information remains private during transmission.
61	IPSec Transmission mode	Transport mode and Tunnel Mode
62	• Transport mode	Only the payload (data) of the IP packet is encrypted and/or authenticated, while the header remains intact. It is typically used for end-to-end communication between two hosts.
63	• Tunnel mode	The entire IP packet, including both the header and payload, is encrypted and/or authenticated, and a new IP header is added. It is commonly used for securing communication between networks or between a client and a VPN gateway.
64	Architectures and implementation of IPSec	Host to Host Network To Network VPN Gateway Arch. Hybrid Arch.
65	• Devices	Routers Firewalls VPN Gateways Security Appliances
66	• Integration into TCP/IP	IPSec Protocols Authentication Header (AH) Encapsulating Security Payload (ESP) Security Associations (SAs) Internet Key Exchange (IKE)

67	Architectures	Host-to-Host Architecture: IPSec is implemented directly on end devices (hosts), where communication between two individual devices is secured. Network-to-Network Architecture: IPSec is implemented at the network level, protecting communication between two or more networks. A VPN gateway (such as a router or firewall) implements IPSec to secure data between remote clients and corporate networks. Hybrid Architecture: A combination of host-to-host and network-to-network implementations, providing both individual device security and broader network communication protection
More Protocols		
68	Hypertext Transport Protocols Secure (HTTPS)	an extension of HTTP that uses encryption protocols like SSL/TLS to secure data exchanged between a user's browser and a web server, ensuring confidentiality, data integrity, and authentication during communication.
69	Secure Shell (SSH)	a cryptographic network protocol used to securely access and manage devices over an unsecured network, providing encrypted communication for tasks like remote login, file transfers, and executing commands.
70	Secure/Multipurpose Internet Mail Extension (S/MIME)	is a standard for public key encryption and signing of MIME data, commonly used to secure email communications by providing confidentiality, data integrity, and authentication through digital signatures and encryption.
71	Secure real-time transport protocol (SRTP)	is a protocol used to secure audio and video communications over IP networks, providing encryption, message authentication, and integrity, ensuring the confidentiality and reliability of real-time data streams like VoIP and video calls.
72	Hardware Security Module (HSM)	is a physical device used to generate, store, and manage cryptographic keys securely, providing tamper-resistant protection for sensitive data and supporting operations like encryption, decryption, and digital signing.
73	Trusted Execution Environment (TEE)	is a secure area within a processor that isolates and protects sensitive data and code from the rest of the system, ensuring confidentiality and integrity even if the main operating system is compromised.
74	Trusted Platform Module (TPM)	a dedicated hardware chip that provides secure generation, storage, and management of cryptographic keys, ensuring the integrity of the system by protecting against unauthorized access and tampering.
Implementation of Cryptography		
75	Key strength	refers to the size or length of a cryptographic key, typically measured in bits

76	Randomness	in cryptography refers to the unpredictability of generated values, ensuring that cryptographic keys, initialization vectors, and other sensitive data are not predictable, thus providing robust security against attacks.
77	Cryptoperiod	refers to the time duration during which a cryptographic key is considered secure for use before it should be replaced or retired to mitigate risks of exposure or compromise.
76	Key Length	refers to the size of a cryptographic key, typically measured in bits, and determines the potential number of combinations for the key
77	Key space	refers to the total number of possible cryptographic keys that can be generated based on the key length, with a larger key space offering greater security by increasing the difficulty of key prediction or brute-force attacks.
78	Block cipher mode algorithm	refers to the method in which a block cipher is applied to data, defining how plaintext is divided and processed into fixed-size blocks, and how encryption is performed.
79	Authentication mode of operation	refers to the method used to verify the authenticity and integrity of data in cryptographic systems. It ensures that the data has not been tampered with and that it originates from a legitimate source.
80	authentication mode of operation	refers to the method used to verify the authenticity and integrity of data in cryptographic systems. It ensures that the data has not been tampered with and that it originates from a legitimate source.
81	Common mode of operation	in cryptography refer to different methods used to apply block ciphers to data for encryption and decryption.
82	Electronic code book (ECB)	is a mode of operation for block ciphers where the plaintext is divided into fixed-size blocks, and each block is independently encrypted with the same key
83	Cipher Block Chaining (CBC)	is a block cipher mode of operation where each plaintext block is XORed with the previous ciphertext block before being encrypted
84	Counter (CTR)	is a mode of operation for block ciphers where a counter value is encrypted and then XORed with the plaintext to produce ciphertext
85	Galois/Counter (GCM)	is an authenticated encryption mode that combines the Counter (CTR) mode of encryption with a Galois field multiplication for authentication